Cortex AppSec Documentation - Detailed

1. Cortex Cloud Application Security

- note: While some features are included by default, others require a dedicated add-on purchase.

2. Onboard data sources

- note: Third-party SCA ingestion (such as Snyk, Semgrep) covers CVE vulnerabilities only. License Miscompliance and Package Operational Risk findings are produced exclusively by the native Cortex Cloud SCA scanner. You must enable native SCA scanning to achieve license and operational-risk coverage
- 2.1. Onboard version control systems
  - note: Cortex Cloud Application Security (which includes IaC and Secrets scanning), is an add-on to a license (such as Posture Security) that must be purchased separately.
  - note: Disclaimer: When onboarding with third-party data sources, we outline the required steps for setup, but we do not monitor these external resources, and they may change over time. Always refer to the relevant third-party documentation for the most current integration steps.
  - tip: Navigate to Settings → Data Sources & Integrations → + Add New → and enter your VCS data source in the search bar.
  - 2.1.1. AWS CodeCommit
    - prer…: Before you begin, ensure the following:
      Cortex Cloud user permissions: Ensure you have View/Edit permissions for Data Sources and Integrations (RBAC: AppSec Admin or Instance Administrator)
      AWS user permissions: To onboard CodeCommit, the user logged into the AWS Console must have permissions to deploy the CloudFormation stack and authorize the…
    - tip: The instance ID is identical to the stack ID on the AWS platform.
    - navi…: Modules → Application Security → Periodic scans
  - 2.1.2. Azure DevOps
    - prer…: Before you begin:
      Cortex Cloud user permissions: Ensure you have View/Edit permissions for Data Sources and Integrations (RBAC: AppSec Admin or Instance Administrator)
      Azure DevOps permissions: Ensure the user performing the integration holds one of the following roles in Azure DevOps:
      Project Administrator: This permission is required to subscribe…
    - note: This forces Azure to bypass browser cookies and issue a token for the correct directory.
    - note: PATs are static. To onboard a different tenant, you must log in to that specific environment to generate a new token.
    - imp…: When redirected to the Microsoft login screen, do not immediately enter your email.
    - navi…:
      - Settings → Data Sources & Integrations → + Add New
      - User Settings → Personal access tokens → + New Token
    - 2.1.2.1. Azure DevOps onboarding system architecture
      - note: Microsoft has announced the deprecation of legacy OAuth methods by 2026, making Entra ID the required standard for long-term support.
  - 2.1.3. Bitbucket Cloud
    - prer…: Before you begin:
      Cortex Cloud user permissions: Ensure you have View/Edit permissions for Data Sources and Integrations (RBAC: AppSec Admin or Instance Administrator)
      Bitbucket permissions: In Bitbucket, grant the user performing the Cortex application authorization the following permissions. The level of access required depends on the modules you…
    - note: Ensure that you receive the Instance Successfully Created message on this step, indicating successful instance creation.
  - 2.1.4. Bitbucket Data Center
    - prer…: Before you begin:
      Cortex Cloud user permissions: Ensure you have View/Edit permissions for Data Sources and Integrations (RBAC: AppSec Admin or Instance Administrator)
      Bitbucket authorization (PAT): You must generate a Personal Access Token (PAT) within your Bitbucket Server account settings to authenticate the connection. For detailed instruction on…
    - note: For more information about the Transporter, including setup instructions, refer to Transporter over Broker VM.
    - note: Ensure that you receive the Instance Successfully Created message on this step, indicating successful instance creation.
    - note: By default, the permissions of the access token are set according to your current access level. It is essential to define two levels of permissions, Project and Repository permissions. The Repository permissions inherit from Project permissions, requiring Repository permissions to match or exceed Project permissions
      Providing read and write permissions…
    - note: For additional security, it is recommended to set an expiry automatically. The expiry date of a token cannot be changed after it is created. You can see the expiry dates for all your tokens on Profile picture → Manage account → Personal access tokens.
    - imp…: Always refer to the Bitbucket documentation for information relating to creating a PAT.
  - 2.1.5. GitHub Cloud
    - prer…: Before you begin:
      Cortex Cloud user permissions: Ensure you have View/Edit permissions for Data Sources and Integrations (RBAC: AppSec Admin or Instance Administrator)
      In GitHub, grant the user performing the Cortex application authorization the following permissions:
      Organization Owner: Only an Organization Owner can directly authorize and install…
    - navi…: Verify integration: On Data Sources, select Code Providers → GitHub SaaS → View more and confirm that the status of your integrated GitHub instance is 'Connected
  - 2.1.6. GitHub Enterprise (On-Prem)
    - prer…: Before you begin:
      Cortex Cloud user permissions: Ensure you have View/Edit permissions for Data Sources and Integrations (RBAC: AppSec Admin or Instance Administrator)
      GitHub permissions: You must have Organization Owner permissions to install the Cortex application. Users with only repository-level admin permissions cannot complete the installation…
    - note: The domain is the hostname associated with your GitHub Enterprise (On-Prem) instance.
    - note: For more information about the Transporter, including setup instructions, refer to Transporter over Broker VM.
    - note: Ensure that you receive the Instance Successfully Created message on this step, indicating successful instance creation.
  - 2.1.7. GitLab SaaS
    - prer…: Before you begin:
      Cortex Cloud user permissions: Ensure you have View/Edit permissions for Data Sources and Integrations (RBAC: AppSec Admin or Instance Administrator)
      In Gitlab, the following permissions are required to integrate the application:
      Maintainer (Project-level). Grants sufficient permissions to configure external integrations, manage…
    - note: A repository can only be integrated with a single instance. The first instance that connects with the repository will be the one that the repository is assigned to. This means that if multiple integrations attempt to connect to the same repository, only the first integration to establish the connection will be associated with that repository.
  - 2.1.8. GitLab Self Managed (On-Prem)
    - prer…: Cortex Cloud user permissions: Ensure you have View/Edit permissions for Data Sources and Integrations (RBAC: AppSec Admin or Instance Administrator)
      Gitlab permissions: Authorize the user integrating Cortex Cloud Application Security with your GitLab Self Managed (On-Prem) instances with the following permissions:
      Maintainer permissions. Grants…
    - note: The domain is the hostname associated with your GitLab Self Managed (On-Prem) instance.
    - note: For more information about the Transporter, including setup instructions, refer to Transporter over Broker VM.
    - note: Ensure that you receive the Instance Successfully Created message on this step, indicating successful instance creation.
- 2.2. Onboard CI/CD systems
  - 2.2.1. CircleCI for CI/CD pipeline scans
    - prer…: Before you begin:
      Cortex Cloud user permissions: Ensure you have View/Edit permissions for Data Sources and Integrations (RBAC: AppSec Admin or Instance Administrator)
      CircleCI user requirements:
      Permissions: To enable Cortex Cloud visibility for all CircleCI projects, a version control system (VCS) user with integration permissions must be…
    - note: This integration utilizes a Personal Access Token (PAT) for authentication
      CircleCI onboarding offers both code and CI/CD scanning. A single integrated instance supports either code or CI scanning, but not both. If you require both code and CI scanning for your CircleCI environment, you must create two separate integrations, selecting the appropriate…
  - 2.2.2. Jenkins for CI/CD pipeline scans
    - prer…: Cortex Cloud user permissions: Ensure you have View/Edit permissions for Data Sources and Integrations (RBAC: AppSec Admin or Instance Administrator)
      In Jenkins:
      To install and configure the Cortex plugin in Jenkins, you must be a Jenkins Administrator with Overall/Administer permissions
      Ensure the build server allows outbound HTTPS (Port 443…
    - note: Jenkins onboarding offers both code and CI/CD scanning. A single integrated instance supports either code or CI scanning, but not both. If you require both code and CI scanning for your Jenkins servers, you must create two separate integrations, selecting the appropriate scanning type for each. To onboard Jenkins for code scans, refer to Jenkins for…
    - note: The integration is added on the console but integration is pending, and will only be completed after completing step 5 below. You can view the pending integration on the Jenkins Instances page: Select Data Sources → Jenkins → View Details. The type of integration is Pipeline Risks
    - note: Always refer to the official Jenkins documentation when installing plugins on Jenkins servers.
- 2.3. Integrate CI tools
  - navi…:
    - Settings → Data Sources & Integrations → hover over a CI tool → View Details
    - Delete an instance: Right-click on an instance of the CI tool → Delete instance → Delete
  - 2.3.1. AWS CodeBuild
    - prer…: Before you begin:
      User permissions: Ensure the user performing the integration has permissions to edit pipeline configurations (such as YAML files) and manage secrets/credentials within the CI platform to store the Cortex Cloud API key securely
    - note: Do not change the names of the environment variables provided by Cortex Cloud. They are required for proper integration and functionality.
    - note: The code is only a reference. Replace the placeholder values with your build-specific values.
  - 2.3.2. CircleCI for code scans
    - prer…: Before you begin:
      User permissions: Ensure the user performing the integration has permissions to edit pipeline configurations (such as YAML files) and manage secrets/credentials within the CI platform to store the Cortex Cloud API key securely
    - note: CircleCI onboarding offers both code and CI/CD scanning. A single integrated instance supports either code or CI scanning, but not both. If you require both code and CI scanning for your CircleCI environment, you must create two separate integrations, selecting the appropriate scanning type for each. To onboard CircleCI for CI/CD scans, refer to…
    - note: Do not change the names of the environment variables provided by Cortex Cloud. They are required for proper integration and functionality.
    - imp…: The cortex-secrets naming convention for the context is mandatory to ensure functionality and must not be changed.
  - 2.3.3. Connect Cortex CLI
    - prer…: System requirements:
      macOS (Intel Core i7, such as Sequoia): To ensure all functionalities work correctly, you must install the vectorscan dependency via Homebrew, using this command: brew install vectorscan
      RHEL 8.10 and Red Hat UBI9: The following prerequisites must be met:
      Install patchelf
      Install zstd
      Ubuntu 20 requires the prefetch…
    - note: The Cortex CLI requires an API key with the Standard security level.
    - note: On macOS arm 64 architecture you must unpack the downloaded file to retrieve the executable.
    - navi…:
      - If needed, retrieve your public API URL by navigating to Settings → Configurations → API Keys and clicking Copy API URL, then paste it into the code
      - Windows installer → uninstall via Settings → Apps → Installed apps, or delete the
  - 2.3.4. GitHub Actions
    - prer…: Before you begin:
      User permissions: Ensure the user performing the integration has permissions to edit pipeline configurations (such as YAML files) and manage secrets/credentials within the CI platform to store the Cortex Cloud API key securely
    - note: Do not change the names of the environment variables provided by Cortex Cloud. They are required for proper integration and functionality.
    - note: The code is only a reference. Replace the placeholder values with your build-specific values.
  - 2.3.5. Jenkins for code scans
    - prer…: Grant Administrator permissions to the user integrating Cortex Cloud Application Security with Jenkins
      Egress path: Create an egress path to establish the designated route for outbound data transmission from Cortex Cloud to third party services. For more information about configuring egress paths, refer to Egress configurationsEgress configurations
    - prer…: For Cortex Cloud Application Security CI tools, you must store secrets in Jenkins Credentials for use in your Jenkins pipelines using either of these methods:
      Plain text storage: Store secrets directly as plain text in Jenkins Credentials. Access them in your pipeline using the credentials function, which retrieves the secret directly as plain…
    - note: Jenkins onboarding offers both code and CI/CD scanning. A single integrated instance supports either code or CI scanning, but not both. If you require both code and CI scanning for your Jenkins servers, you must create two separate integrations, selecting the appropriate scanning type for each. To onboard Jenkins for CI/CD scans, refer to Jenkins for…
    - note: This step is only required for new pipelines
      For private repositories, ensure the necessary credentials are configured in Jenkins Credentials
    - note: This ensures your build runs within a Docker environment. If a node without Docker is used, the build will fail.
  - 2.3.6. Terraform Cloud (Run Tasks)
    - prer…: Before you begin:
      User permissions: Ensure the user performing the integration has permissions to edit pipeline configurations (such as YAML files) and manage secrets/credentials within the CI platform to store the Cortex Cloud API key securely
      Procure a Terraform cloud license that is either a trial license or a TF Cloud license at the TEAM &…
    - note: Skip this step if you plan on using an existing token.
    - note: Cortex Cloud Application Security performs a scan of Terraform templates on selected workspaces based on the Run Stage.
  - 2.3.7. Terraform Enterprise (Run Tasks)
    - prer…: Before you begin:
      Ensure access to a Terraform Enterprise console to enable you to provide a user or team token that authorizes Cortex Cloud Application Security to access workspaces and helps regulate run configurations
      Terraform Enterprise version compatibility: Ensure Run Tasks for workspaces on is compatible with version 1.1.9 and above Terraform…
    - note: For container image vulnerabilities, Cortex Cloud Application Security performs 'Image Referencer' scans within Terraform Enterprise (Run Tasks), as full SCA scans are not currently supported.
    - note: Skip this step if you plan on using an existing token.
    - note: Cortex Cloud Application Security performs a scan of Terraform templates on selected workspaces based on the Run Stage.
- 2.4. CLI pipeline code snippets
  - prer…: User permissions: Ensure the user performing the integration has permissions to edit pipeline configurations (such as YAML files).
- 2.5. Onboard private package registries
  - 2.5.1. JFrog Artifactory
  - 2.5.2. Onboard JFrog Artifactory
    - prer…: Cortex Cloud user permissions: Ensure you have View/Edit permissions for Data Sources and Integrations (RBAC: AppSec Admin or Instance Administrator)
      JFrog permissions:
      The permissions associated with the user configured during the onboarding process determine the scope of scan results. Only repositories and artifacts the user can access are…
    - note: To authorize the scanner to connect through your firewall, select Enable access by IPs, and copy the displayed source IPs to your organization's allowlist.
    - note: For Maven:
      Select Mirror Registry if this repository mirrors an external repository
      Use the Mirror Of value to define the duplication scope:
      * mirrors all requests
      Type a request [value]: Mirrors only specific requests (such as central).
      For Maven:
      Select Mirror Registry if this repository mirrors an external repository
      Use the Mirror Of…
- 2.6. Ingest third-party data sources
  - note: Only onboarded and scanned repositories can be mapped.
  - 2.6.1. Semgrep
    - prer…: Cortex Cloud user permissions: Ensure you have View/Edit permissions for Data Sources and Integrations (RBAC: AppSec Admin or Instance Administrator)
      Ensure that you have a connected version control system (VCS) and repositories
      Semgrep: A valid Semgrep API token
      Note
      To create a Semgrep API token, in Semgrep, navigate to Settings → Tokens →…
    - note: Mapping establishes relationships between Semgrep projects and Cortex Cloud code repositories, simplifying access management and enabling risk analysis at the repository level, including displaying findings on the tenant
      Only mapped projects are ingested
    - note: Requisite RBAC permissions are required for edit and delete operations.
    - imp…: Deletion is irreversible. To restore Semgrep findings after deletion, reconfigure the integration and wait for the next polling cycle to re-ingest findings from Semgrep.
    - 2.6.1.1. Semgrep Software Composition Analysis (SCA) data ingestion
      - navi…: Application Security → Issues → Vulnerabilities
    - 2.6.1.2. Semgrep Static Application Security Testing (SAST) data ingestion
      - navi…: Application Security → Issues → Code Weaknesses
  - 2.6.2. Snyk
    - prer…: Permissions: The following user permissions are required:
      Cortex Cloud user permissions: Ensure you have View/Edit permissions for Data Sources and Integrations (RBAC: AppSec Admin or Instance Administrator)
      Ensure that you have a connected version control system (VCS) and repositories
      Snyk permissions and requirements:
      Permissions: The…
    - note: Select Test Connection to verify that Cortex Cloud can connect to your Snyk organization.
    - note: SCA requires Snyk Open Source or Snyk Container projects configured in the organization
      SAST requires Snyk Code enabled and projects configured in the organization
    - note: Mapping establishes relationships between Snyk applications and Cortex Cloud code repositories, simplifying access management and enabling risk analysis at the repository level, including displaying findings on the tenant
      Only mapped applications are ingested
    - note: Requisite RBAC permissions are required for edit and delete operations.
    - imp…: Snyk Free tier is not supported. A paid Snyk plan (Team, Business, or Enterprise) is required to ingest findings from Snyk.
    - 2.6.2.1. Snyk Software Composition Analysis (SCA) ingestion
      - navi…: Modules → Application Security → Vulnerabilities (under Issues
    - 2.6.2.2. Snyk Static Application Security Testing (SAST) data ingestion
      - navi…:
        - Modules → Application Security → Code Weaknesses
        - Modules → Application Security → AppSec Coverage
  - 2.6.3. SonarQube
    - prer…: Cortex Cloud user permissions: Ensure you have View/Edit permissions for Data Sources and Integrations (RBAC: AppSec Admin or Instance Administrator)
      Ensure that you have onboarded a version control system (such as GitHub, GitLab) and have connected repositories
      SonarQube and SonarCloud setup:
      Token requirements: The API token for both SonarCloud…
    - note: Mapping establishes relationships between SonarQube Applications and Cortex Cloud Application Security code repositories, simplifying access management and enabling risk analysis at the repository level, including displaying findings on the tenant
      Only mapped projects will be ingested
    - note: Verify that the Connector Created Successfully message is displayed on the page.
  - 2.6.4. Veracode
    - prer…: Permissions: The following user permissions are required:
      Cortex Cloud: Instance Admin, AppSec Admin or GRBAC permissions. For more information on AppSec Admin permissions, refer to Code Security user roles and permissionsCode Security user roles and permissions are required
      Veracode: At minimum, Reviewer permissions are required
      Permissions: The following…
    - note: Only mapped applications will be ingested.
    - note: This is the recommended option to ensure complete coverage and successful operation of all features.
    - note: Mapping establishes relationships between Veracode projects and Cortex Cloud Application Security code repositories, simplifying access management and enabling risk analysis at the repository level, including displaying findings on the tenant
      Only mapped projects will be ingested
    - note: Verify that the Connector Created Successfully message is displayed on the page.
  - 2.6.5.1. Tenant (console) workflow
    - note: Editing a collector does not regenerate the API credentials. The existing credentials remain valid after editing the collector name.
    - imp…: The Token ID and API Token are displayed only once. Copy and store the credentials securely before proceeding. If the credentials are lost, edit the collector to regenerate the credentials.
    - caut…: Deleting a collector permanently removes the collector instance and invalidates the associated API credentials. Existing findings that were previously ingested through the deleted collector remain in the platform and are not affected by the deletion.
    - navi…:
      - Settings → Data Sources & Integrations → 3rd Party AppSec Collector
      - Settings → Data Sources → 3rd Party AppSec Collector

4. Application Security Posture Management (ASPM)

- note: ASPM does not execute scans. Detection and finding generation belong to Code Security (native scanners) and the Supply Chain Security pillar (VCS repository and CI/CD pipeline analysis). ASPM evaluates the findings against unified policies and orchestrates the resulting issues through to remediation.
- navi…: You can view AppSec Admin permissions in the tenant by navigating to Settings → Configurations → Roles → AppSec Admin
- 4.1. Code to Cloud
  - navi…: Full Code to Cloud (C2C) coverage is achieved when Cortex Cloud can resolve the following chain: Repository → Pipeline → Image → (optional Registry) → Runtime resources (including VMs, VM images, and IaC-defined infrastructure
  - 4.1.1. Supported integrations
  - 4.1.2. Code to Cloud context and visibility
    - navi…: Topology graph: Located in the Business Applications side card, this tab visualizes the entire path to production (Code → Build → Deploy → Run), allowing you
  - 4.1.3. Code to Cloud troubleshooting
    - note: Empty state messages and troubleshooting guidance for missing lineage are only visible to users with an active license.
- 4.2. ASPM Command Center
  - 4.2.1. Operational workflows
- 4.3. Applications
  - 4.3.1. Defining Business Applications
    - 4.3.1.1. Defining business applications by Criteria
    - 4.3.1.2. Manage Criteria via the tenant UI
      - navi…: Modules → Application Security → Application Management → Criteria
    - 4.3.1.3. Define applications by VCS Criteria
      - prer…: Data source: Your Version Control System (such as GitHub, GitLab) must already be onboarded as a Data Source
        Permissions: You must have View/Edit permissions for Access Management
        SBAC: You can only create applications from VCS entities (Organizations, Projects, or Repositories) that are already included in your SBAC Asset Groups
      - note: This workflow allows you to unify assets across disparate providers (such as grouping a GitHub repository and a Bitbucket repository into one application) if they share naming conventions
    - 4.3.1.4. Define applications by cloud tag-based Criteria
      - prer…: Permissions: You must have View/Edit permissions for Access Management, or a role that includes these permissions.
      - note: You can only create applications based on the entities from onboarded Cloud accounts listed in the Cloud card.
      - note: Kubernetes (K8S) labels: K8S labels are supported as tags for asset grouping only when they originate from a supported cloud provider; AWS, GCP, Azure, or OCI.
    - 4.3.1.5. Manage criteria via the public API
    - 4.3.1.6. How to manually build an application
      - prer…: Before you begin, ensure you have connected the necessary data sources. Refer to How to onboard data sources for more information.How to onboard data sources
      - note: These filters are represented by icons displayed on the Code pane after selecting a VCS.
      - note: To edit application assets, click the Clear All icon before clicking Finish. This clears all application data, allowing you to restart the application building process from the beginning.
  - 4.3.2. Application management and visibility
    - navi…: Inventory → All Assets → Business Applications (under Application
  - 4.3.3. Manage applications via public APIs
    - note: The application public API does not execute scans, enforce policies, or create issues. Scanning, policy enforcement, and issue creation are performed by their respective subsystems (Unified Application Security policies, scanner orchestration).
  - 4.3.4. Business application assets
    - 4.3.4.1. Business application expanded asset details
      - note: The topology graph is available only when all application components (code, pipeline, build and deploy), are configured.
    - 4.3.4.2. Export business application data
      - navi…: Inventory → All Assets → Business Applications
  - 4.3.5. Scope user access to applications (Application SBAC)
    - navi…: Configure user scopes in Cortex Cloud by navigating to Settings → Configurations → Access Management
    - 4.3.5.1. Enable SBAC in the Cortex Cloud tenant
      - prer…: RBAC permissions: To configure user scopes you must have Administrator or View/Edit RBAC permissions for Access Management (under Configurations).
      - note: Exclusions (roles not governed by SBAC): Certain roles cannot have SBAC applied. For these roles, access and permissions are managed through Role-Based Access Control (RBAC). You must manually ensure that these roles have all necessary base permissions (for example Edit/View permissions to assets), because SBAC is bypassed and does not impose its usual…
      - navi…: Settings → Configurations → General → Server Settings → Enable Scope Based Access Control
    - 4.3.5.2. Create an application-based Asset Group
      - note: You cannot create SBAC based on static groups.
    - 4.3.5.3. Scope user access to an application
      - note: For more information about User Groups, refer to User group management.User group management
      - navi…:
        - Settings → Configurations → User Groups (under Access Management
        - Right-click on a group in the table → Edit Group → select the Scope tab
        - Assets → Select asset groups → select an Asset Group associated with applications
        - Settings → Configurations → Users (under Access Management
        - the chevron icon (>) in the Assets field → Select Asset groups → select the user group scoped to the application (see above
    - 4.3.5.4. Create application-scoped policies
      - note: Application-scoped policies apply to both code and CI/CD configuration policies.
      - navi…:
        - Modules → Application Security → AppSec Polices (under Policy Management) → Add Policy
        - Add Filter → Business Application Names → enter the required application name
    - 4.3.5.5. Terraform workflow for Asset Groups
- 4.4. Repository as an asset
  - 4.4.1. Understanding repository assets via the UI
    - navi…: To access repository assets, under Inventory, select All Assets → Code → Repositories
  - 4.4.2. Investigate repository assets
    - navi…: From the Repositories table, right-click a repository → Open in Agentic Assistant → select Application Security from the agents menu, and query repository-specific insights (for example, scan coverage, risk posture, or gaps
  - 4.4.3. Manage repositories via API
    - note: The public API base path is /public_api/appsec/v1/repositories.
    - note: The excludedPaths field replaces the entire excluded paths list; to add a new path, retrieve the current configuration first, append the new path, and send the complete array
      SAST: SAST scanner configuration is not available through the public API and must be managed through the console UI
    - war…: Always retrieve the current branch list before updating. The PUT operation replaces the entire branch selection, meaning any omitted branches will be unintentionally removed from scanning.
- 4.5. Coverage
  - 4.5.1. Coverage in the user interface
    - navi…: Modules, → Application Security → AppSec Coverage
- 4.6. Urgency
  - 4.6.1. Urgency and code to cloud traceability
    - imp…: Without code to cloud traceability, deployment-related urgency signals cannot be computed. Scanner-specific signals (EPSS Score, KEV Status, Reachability, Secret Validation, CWE Top 25, OWASP Top 10) are always available regardless of code to cloud traceability.
  - 4.6.2. Prioritize issues by Urgency levels
  - 4.6.3. Urgency metrics
  - 4.6.4. View Urgency in the tenant
    - note: EPSS Score, CVSS Score, Exploit Maturity, Exploit Availability, Fixable, Is Deployed, Visibility, Validation metrics are displayed even when the value is false or zero. Other metrics are displayed only when the value is present and non-null
      For more about Urgency metrics refer to Urgency metrics
    - tip: Combine Urgency filters with scanner type filters to focus on the highest-risk issues for a specific scanner category (for example, Top Urgent vulnerability issues or Urgent secrets issues).
- 4.7. Backlog baseline
  - 4.7.1. Backlog use cases
  - 4.7.2. Issue/Finding classification by scanner
    - note: In some cases/vendors, this is not accurate as findings are deleted every time new findings are uploaded. In such cases, the feature may not be accurate or supported
      For SAST, the vendor does not support policy in pull requests
    - note: Scanner updates and new detections: When a security scanner is updated to support new languages, detection rules, or capabilities, any issues discovered by these new features for existing code are classified as part of the backlog.
  - 4.7.3. Using Backlog
    - navi…:
      - Settings → Configuration → Application Security → AppSec Issues Configurations and enable Are SBOM issues considered new
        Permissions for all other capabilities, such as viewing issues or applying policies, are defined by the existing RBAC/SBAC policies and the user's specific issue management capabilities
      - Settings → Configuration → Application Security → AppSec Issues Configurations and enable Are SBOM issues considered new
- 4.8. Service Lead Agreements (SLA)
  - 4.8.1. Configure and monitor Cortex Cloud Application Security SLAs
    - navi…: Settings → Configurations → Application Configuration (under Application Security
- 4.9. Compliance for Cortex Cloud Application Security
  - 4.9.1. Infrastructure-as-Code (IaC) compliance
  - 4.9.2. Manage IaC compliance
    - prer…: Add these properties to the IaC Rules table through the Table Settings Menu, as they are not exposed by default.
    - prer…: Add these properties to the tables table through the Table Settings Menu, as they are not exposed by default.
    - navi…:
      - Modules → Application Security → AppSec Polices → Add Policy
      - Modules → Application Security → IaC Misconfigurations (under Issues
  - 4.9.3. CI/CD Compliance
    - 4.9.3.1. Create CI/CD compliance reports
      - note: The CI/CD module supports GitHub and GitLab provider types.
      - note: For more information about about Asset Groups, refer to Asset groups.Asset groups
      - note: CIS GitLab Benchmark, CIS GitHub Benchmark, and the OWASP Top 10 CI/CD Risks standards are supported.
      - note: For more information about assessment profiles, refer to Use an assessment profile to run compliance checks on your assets.Use an assessment profile to run compliance checks on your assets
      - navi…: Posture Management → Compliance → Reports
  - 4.9.4. Terraform workflow for Compliance assessments
- 4.10. Unified Application Security policies
  - 4.10.1. Core concepts
    - note: The Policy Type selection determines the available configuration options for conditions, filters, and triggers.
    - note: For a full description of each finding type and its applicability (Code vs. Image), refer to Reference A: Finding type details.
    - note: For a complete list of all available filters by category, as well as logical groups, refer to Reference B: Condition filters and logic.
    - note: To understand the specific calculation logic and how grace periods align with your organization's SLAs, refer to Reference E: Grace period logic and configuration.
    - note: Application scoping is currently not supported for Build Images
    - note: Images do not have a default severity. You must select a severity to continue when any image trigger is selected.
  - 4.10.2. Tenant (UI) workflow
    - note: SBAC restricts table visibility. The policy table displays only policies scoped to assets within the user's assigned application boundary. Policies scoped to assets outside the user's SBAC scope are not visible
    - navi…:
      - Posture Management → Rules & Policies → Policy → Application Security The policy table displays all policies (out-of-the-box (OOTB) and custom
      - Posture Management → Rules & Policies → Policy → Application Security
  - 4.10.3. Create a policy
    - note: To create a new asset group or application, select the corresponding link in the scope step. The link opens the asset group or application configuration in a new tab
  - 4.10.4. View and manage policy details
    - caut…: Deleting a policy closes all issues created by that policy during the next periodic scan. This action cannot be undone. Consider disabling the policy instead of deleting the policy to preserve issue history.
    - navi…:
      - Modules → Application Security → Issues → All
      - Modules → Application Security → Scans
  - 4.10.5. API workflow
    - note: The public API remains backward compatible with existing API consumers. The API returns additional fields for the unified policy structure, including the new policy type, trigger configuration, and Override Severity settings.
  - 4.10.6. Cortex CLI workflow
  - 4.10.7. IDE workflow
  - 4.10.8. Terraform workflow for policies
  - 4.10.9. Reference A: Finding type details
  - 4.10.10. Reference B: Condition filters and logic
    - note: When multiple finding types are selected within a single condition group, only the Common filters (such as Severity or Backlog Status) are available for selection.
  - 4.10.11. Reference C: Scope mapping details
  - 4.10.12. Reference D: Trigger and actions mapping
  - 4.10.13. Reference E: Grace period logic and configuration
  - 4.10.14. Reference F: Engine evaluation and Urgency logic
    - note: If code to cloud traceability is absent (the repository is not linked to a relevant application), the engine cannot compute deployment signals, and Urgency will display as Not Applicable
  - 4.10.15. Reference G: Finding type to trigger mapping
    - note: Malware findings are applicable to image scans only When a CI Scan includes image scanning, Malware findings are evaluated PR Scan and Periodic Scan do not evaluate Malware findings
    - note: CI/CD Configuration Scanners policies support only the Periodic Scan trigger PR Scan and CI Scan triggers are not available for the CI/CD Configuration Scanners policy type
    - note: Drift Detection Scanner policies support only the Periodic Scan trigger PR Scan and CI Scan triggers are not available for the Drift Detection Scanner policy type
  - 4.10.16. Reference H: Action availability by trigger
  - 4.10.17. Reference I: Audit logging
    - navi…: Settings → Configurations → Management → Audit Logs to review policy audit entries
- 4.11. Application Security Rules
  - note: The AppSec rules API manages rule definitions and metadata. It does not execute scans, create issues, or enforce policies.
  - 4.11.1. Roles and permissions
    - note: Custom roles can be configured with either View or View/Edit permissions for AppSec rules API keys inherit the permissions of the role assigned during key generation. To perform write operations (create, modify, delete) through the AppSec rules API, the API key must have a role that includes View/Edit permissions
  - 4.11.2. Rules inventory
    - navi…: To filter rules relating to Secrets, select filter icon → Scanner (from the Select field) → Secrets (from the Value field
  - 4.11.3. Create custom Cortex Cloud Application Security rules
    - note: See Configure YAML file properties below for more details.
  - 4.11.4. Configure YAML file properties
  - 4.11.5. Terraform workflows for rules
  - 4.11.6. Manage custom rules
- 4.12. Manage code weakness issues
  - 4.12.1. Navigate to SAST code weakness issues
    - note: The default sort order is by Severity (descending). The default filter shows issues with a status of New and In Progress. Resolved issues are hidden by default.
    - note: Findings in the Findings tab are raw scanner output and do not have resolution statuses, SLA tracking, or assignees. To track remediation for a specific finding, create or update a unified policy that matches the finding pattern to generate an actionable issue in the Issues tab.
    - navi…: To access SAST code violation issues, under Modules, select Application Security → Issues → Code Weaknesses
  - 4.12.2. Understand the Code Weaknesses table
  - 4.12.3. Investigate and remediate code weakness issues
    - imp…: Important: Urgency signals are populated only when the SAST asset is traced to deployed cloud resources through the Code-to-Cloud mapping. If no Code-to-Cloud trace exists, urgency signals display as Not Applicable
    - navi…:
      - From the main issues table: Right-click on an issue in the table → Change Status → [Select a status
      - From the main issues table: Right-click on an issue in the table → Change Assignee → [Select a user
      - From the main issues table: Right-click on an issue in the table → Change Severity → [Select a severity
  - 4.12.4. Code weakness findings
    - note: Findings in the Findings tab are raw scanner output. They do not have resolution statuses, SLA tracking, or assignees. To track remediation for a specific finding, create or update a unified policy that matches the finding pattern to generate an actionable issue in the Issues tab.

5. Software supply chain security

- 5.1. Supply Chain assets
  - 5.1.1. VCS organization assets
    - 5.1.1.1. Understanding VCS organization assets
      - navi…: To access VCS organization assets, under Inventory, select All Assets → Code → VCS Organizations
    - 5.1.1.2. Investigate VCS organization assets
    - 5.1.1.3. Manage VCS organization assets
  - 5.1.2. VCS collaborators as assets
    - 5.1.2.1. In-depth Collaborator asset information
    - 5.1.2.2. Manage Collaborator assets
  - 5.1.3. Repository as an asset
    - 5.1.3.1. Understanding repository assets via the UI
    - 5.1.3.2. Investigate repository assets
    - 5.1.3.3. Manage Repository assets
    - 5.1.3.4. Export Software Bill of Materials (SBOM)
    - 5.1.3.5. Manage issues detected in repositories
      - note: You can also find the repository issues in the general issue inventory table, and in the dedicated inventory of issues for each scanner type (see step 4 above for details).
  - 5.1.4. Technologies as assets
    - note: The filter supports wildcard filtering and is case-insensitive.
    - 5.1.4.1. Manage repository technologies
      - note: The filter supports wildcard filtering and is case-insensitive.
    - 5.1.4.2. Troubleshooting and FAQs
  - 5.1.5. Software packages as assets
    - 5.1.5.1. Understanding software package assets
    - 5.1.5.2. Investigate software package assets and security issues
  - 5.1.6. CI/CD instance as an asset
    - 5.1.6.1. Understanding CI/CD instance assets
      - navi…: To access CI/CD instance assets, under Inventory, select All Assets → Code → CI/CD Instances
    - 5.1.6.2. Investigate and manage CI/CD instance assets
      - note: Navigate to the dedicated Application Security → Issues → CI/CD Risks page to manage the CI/CD risks remediation lifecycle at scale through bulk status updates, team assignments, and SLA tracking for compliance monitoring.
    - 5.1.6.3. Manage CI/CD pipeline instances
  - 5.1.7. CI/CD pipeline as an asset
    - 5.1.7.1. Understanding CI/CD pipeline assets
      - navi…: To access CI/CD pipeline assets, under Inventory, select All Assets → Code → CI/CD Pipelines
    - 5.1.7.2. Investigate and manage CI/CD pipeline assets
      - note: This requires active CI/CD integrations and successful build log analysis. Pipelines without successful build log analysis display only the repository and pipeline nodes
      - note: Navigate to the dedicated Application Security → Issues → CI/CD Risks page to manage the remediation lifecycle at scale through bulk status updates, team assignments, and SLA tracking for compliance monitoring.
      - navi…: From the CI/CD Pipelines table, right-click a pipeline row → Open in Agentic Assistant → Application Security from the agents menu
    - 5.1.7.3. Manage CI/CD pipeline assets
  - 5.1.8. Tools as an asset
    - note: Although attributes are identical across inventories, their values for the same tool can differ, most commonly in Risk Factors and Type. This is because the inventory reflects your live environment, which may include different versions or configurations than the catalog—for example, a package may not have been upgraded or may be deployed differently.
    - navi…: In the inventory table, right-click on a tool → Change Status → select a status
    - 5.1.8.1. Active tools
      - 5.1.8.1.1. Supply Chain Tools
        - navi…: To access Supply Chain Tools, select Modules → Application Security → Supply Chain Tools (under 3rd Party Tools)
      - 5.1.8.1.2. Expanded Supply Chain tool information
        - note: AppSec Admin user permissions are required to perform these actions.
    - 5.1.8.2. Supply chain catalog
      - navi…: To access the Supply Chain Catalog, select Modules → Application Security → Supply Chain Catalog (under 3rd party tools
- 5.2. Software Composition Analysis (SCA) scanners
  - imp…: Utilizing native SCA scanner capabilities requires an AppSec add-on license (Posture Management, Runtime, or Premium Cortex).
  - 5.2.1. Supported Software Composition Analysis (SCA) frameworks and languages
  - 5.2.2. Software Composition Analysis (SCA) vulnerability issues
    - 5.2.2.1. Understand the Vulnerabilities table
    - 5.2.2.2. Investigate and remediate CVE vulnerability issues
      - note: The Open Fix PR action is available only for CVE vulnerability issues detected through periodic scans where an automated fix exists. The action is not available for issues detected through PR scans. Verify that the Is Fixable indicator is True before attempting to open a fix pull request.
      - imp…: Important: Urgency signals related to deployment context are populated only when the SCA asset is traced to deployed cloud resources through the Code-to-Cloud mapping. If no Code-to-Cloud trace exists, deployment-related urgency signals display as Not Applicable. SCA-specific signals (EPSS Score, KEV Status, Reachability, Has Fix) are always available…
    - 5.2.2.3. Investigate CVE vulnerabilities findings
      - note: Findings in the Findings tab are raw scanner output and do not have resolution statuses, SLA tracking, or assignees. To track remediation for a specific finding, create or update a unified policy that matches the finding pattern to generate an actionable issue in the Issues tab.
      - navi…: To access CVE findings, under Modules, select Application Security → Issues → Vulnerabilities → click the Findings tab
    - 5.2.2.4. Manage SCA CVE vulnerability issues
  - 5.2.3. License miscompliance issues
    - 5.2.3.1. Understand the Licenses table
      - note: Important: License miscompliance issues do not have urgency signals. Unlike CVE vulnerability issues, license issues are legal compliance risks — not security vulnerabilities. Urgency signals such as EPSS score, KEV status, reachability analysis, and Code-to-Cloud deployment context do not apply to license compliance evaluation.
    - 5.2.3.2. Take action on license miscompliance issues
      - imp…: Automated fix pull requests are not available for license miscompliance issues. Remediation requires human judgment to evaluate license compatibility, negotiate licensing terms, identify alternative packages, or accept the license with documented justification.
    - 5.2.3.3. License miscompliance findings
      - navi…: To access license miscompliance findings, under Modules, select Application Security → Issues → Licenses → click the Findings tab
    - 5.2.3.4. Open-source software license categories
    - 5.2.3.5. Manage license miscompliance issues
  - 5.2.4. Ingest third-party SCA data
    - navi…: Modules → Application Security → Issues → Vulnerabilities
- 5.3. CI/CD Risks
  - note: Cortex Cloud Application Security CI/CD pipeline scans create a comprehensive inventory of all CI/CD pipelines in your environment. For more information refer to CI/CD pipeline as an asset.
  - 5.3.1. CI/CD pipeline issues
    - navi…: To access CI/CD pipeline risks issues, under Modules, select Application Security → Issues → CI/CD Risks
  - 5.3.2. Expanded CI/CD risks issue information
    - note: Different issue types include different properties; therefore, not all properties are available for every issue.
  - 5.3.3. VCS and CI/CD pipeline risk findings
- 5.4. CI/CD Policies
  - tip: For Cortex Cloud Code policies, refer to Unified Application Security policies.
  - 5.4.1. CI/CD policies user roles and permissions
  - 5.4.2. CI/CD policies inventory
    - note: To view all out-of-the-box (OOTB) policies, filter by Policy Owner = System.
  - 5.4.3. Create CI/CD configuration policies
    - note: When you select a category (such as Application), a list of available asset values for that type is displayed. The policy will automatically apply to all assets in the displayed list unless you apply additional filters using specific asset attributes (such as the Business Application Names filter).
    - note: SBAC scope-based limitations do not apply to Asset Types
    - note: Periodic scan is the only trigger that is supported for CI/CD policies.
    - 5.4.3.1. Cortex Cloud Application Security CI/CD policy Condition attributes
  - 5.4.4. Manage CI/CD policies
    - note: You cannot edit out-of-the-box (OOTB) policies.
    - note: The duplicated policy will include the word "clone" in its name and must be renamed.
- 5.5. CI/CD Rules
  - note: Out-of-the-box rules cannot be modified Custom CI/CD rules are not supported
  - 5.5.1. CI/CD rules roles and permissions
  - 5.5.2. CI/CD rules inventory

6. Code Security

- note: Code Security covers detection and analysis engines. For governance and orchestration layer, see Application Security Posture Management (ASPM).
- navi…: You can view the granular permissions assigned to each role in the tenant by navigating to Settings → Configurations → Roles
- 6.1. Code Security assets
- 6.2. Software packages as assets
  - 6.2.1. Supported Software Composition Analysis (SCA) frameworks and languages
  - 6.2.2. Understanding software package assets
    - navi…: To access software package assets, under Inventory, select All Assets → Code → Software Packages
  - 6.2.3. Investigate software package assets and security issues
- 6.3. Infrastructure-as-Code (IaC) resources as assets
  - 6.3.1. Supported frameworks and languages
  - 6.3.2. Access and filter IaC assets
    - navi…: Inventory, select All Assets → Code → IaC Resources
  - 6.3.3. Investigate IaC assets
- 6.4. Code Security scanners
- 6.5. Secrets scans
  - 6.5.1. Navigate to secrets issues
    - note: The default sort order is by Severity (descending). The default filter shows issues with a status of New and In Progress. Resolved issues are hidden by default.
    - navi…: Under Modules, select Application Security → Issues → Secrets
  - 6.5.2. Understand the secrets issues table
  - 6.5.3. Investigate and remediate secrets issues
    - imp…: Urgency signals related to deployment context are populated only when the secrets asset is traced to deployed cloud resources through the Code-to-Cloud mapping.
  - 6.5.4. Secrets findings
    - note: Review excluded findings: Investigate findings that were excluded by policy filters to confirm that exclusions are intentional and do not suppress critical IaC misconfigurations.
- 6.6. Infrastructure as Code (IaC) misconfiguration scanner
  - 6.6.1. Navigate to IaC misconfiguration issues
    - note: The default sort order is by Severity (descending). The default filter shows issues with a status of New and In Progress. Resolved issues are hidden by default.
    - navi…: To access IaC misconfiguration issues, under Modules, select Application Security → Issues → IaC misconfiguration
  - 6.6.2. Understand the IaC misconfigurations table
  - 6.6.3. Investigate and remediate IaC misconfiguration issues
    - note: The Open Fix PR action is available only for issues detected through periodic scans where an automated fix exists. The action is not available for issues detected through PR scans.
  - 6.6.4. IaC misconfigurationfindings
    - note: Findings in the Findings tab are raw scanner output and do not have resolution statuses, SLA tracking, or assignees. To track remediation for a specific finding, create or update a unified policy that matches the finding pattern to generate an actionable issue in the Issues tab.
    - navi…:
      - To access IaC misconfiguration findings, under Modules, select Application Security → Issues → IaC Misconfigurations → click the Findings tab
      - The Cortex Cloud Application Security IaC misconfigurations Findings table is a filtered view of the comprehensive Findings inventory, located at Cases & Issues → Issues → Findings tab
- 6.7. IaC Drift Detection scans
  - 6.7.1. Navigate to IaC drift detection issues
    - note: The default sort order is by Severity (descending). The default filter shows drift findings with a status of New and In Progress. Resolved drift findings are hidden by default.
    - navi…: Modules → Application Security → IaC Drifts
  - 6.7.2. Understand the IaC drift detection table
  - 6.7.3. Investigate and remediate IaC drift issues
    - note: The Revert to IaC State action requires write permissions on the target cloud account. Verify that the Cortex Cloud service account has the necessary IAM permissions before initiating a revert operation.
    - note: Updating the IaC template codifies the current cloud state as the new desired state. Verify that the cloud resource configuration complies with security policies before merging the generated pull request.
    - navi…:
      - From the main drift table:Right-click on a drift issue in the table → Change Status → Change Status
      - From the main drift table:Right-click on a drift issue in the table → Change Assignee → Change Status
  - 6.7.4. Investigate IaC drift detection findings
    - note: Findings in the Findings tab are raw scanner output and do not have resolution statuses, SLA tracking, or assignees. To track remediation for a specific drift finding, create or update a unified policy that matches the finding pattern to generate an actionable issue in the Issues tab.
    - navi…: Modules → Application Security → IaC Drifts (under Issues) → click the Findings tab
- 6.8. Software Composition Analysis (SCA) scanners
  - 6.8.1. Software Composition Analysis (SCA) vulnerability issues
    - 6.8.1.1. Navigate to CVE vulnerability issues
      - note: The default sort order is by Severity (descending). The default filter shows issues with a status of New and In Progress. Resolved issues are hidden by default.
      - note: Findings in the Findings tab are raw scanner output and do not have resolution statuses, SLA tracking, or assignees. To track remediation for a specific finding, create or update a policy that matches the finding pattern to generate an actionable issue in the Issues tab.
    - 6.8.1.2. Understand the Vulnerabilities table
    - 6.8.1.3. Investigate and remediate CVE vulnerability issues
      - note: The Open Fix PR action is available only for CVE vulnerability issues detected through periodic scans where an automated fix exists. The action is not available for issues detected through PR scans. Verify that the Is Fixable indicator is True before attempting to open a fix pull request.
      - imp…: Important: Urgency signals related to deployment context are populated only when the SCA asset is traced to deployed cloud resources through the Code-to-Cloud mapping. If no Code-to-Cloud trace exists, deployment-related urgency signals display as Not Applicable. SCA-specific signals (EPSS Score, KEV Status, Reachability, Has Fix) are always available…
    - 6.8.1.4. Investigate CVE vulnerabilities findings
      - note: Findings in the Findings tab are raw scanner output and do not have resolution statuses, SLA tracking, or assignees. To track remediation for a specific finding, create or update a unified policy that matches the finding pattern to generate an actionable issue in the Issues tab.
  - 6.8.2. License miscompliance issues
    - 6.8.2.1. Navigate to license miscompliance issues
      - note: The default sort order is by Severity (descending). The default filter shows issues with a status of New and In Progress. Resolved issues are hidden by default.
      - note: Findings in the Findings tab are raw scanner output and do not have resolution statuses, SLA tracking, or assignees. To track remediation for a specific finding, create or update a unified policy that matches the finding pattern to generate an actionable issue in the Issues tab.
      - navi…: Application Security → Issues → Licenses
    - 6.8.2.2. Understand the Licenses table
      - note: Important: License miscompliance issues do not have urgency signals. Unlike CVE vulnerability issues, license issues are legal compliance risks — not security vulnerabilities. Urgency signals such as EPSS score, KEV status, reachability analysis, and Code-to-Cloud deployment context do not apply to license compliance evaluation.
    - 6.8.2.3. Take action on license miscompliance issues
      - imp…: Automated fix pull requests are not available for license miscompliance issues. Remediation requires human judgment to evaluate license compatibility, negotiate licensing terms, identify alternative packages, or accept the license with documented justification.
    - 6.8.2.4. How license miscompliance issues fit in the Application Security ecosystem
      - navi…: Configure unified policies for license compliance at Modules → Application Security → AppSec Policies
    - 6.8.2.5. Open-source software license categories
  - 6.8.3. Package operational risk scanner
    - 6.8.3.1. Understand the package operational risk table
    - 6.8.3.2. Investigate and remediate package operational risk issues
      - note: Automated fix pull requests are not available for package operational risk issues. Remediation requires human judgment to evaluate alternative packages, assess API compatibility, and perform the migration.
      - imp…: Package operational risk issues do not have urgency signals based on exploit intelligence. Unlike CVE vulnerability issues, operational risk issues assess the health and sustainability of a package, not active security vulnerabilities. Urgency signals such as EPSS score, KEV status, and reachability analysis do not apply to operational risk evaluation…
    - 6.8.3.3. How package operational risk issues fit in the Application Security ecosystem
      - navi…: Configure unified policies for operational risk at Modules → Application Security → AppSec Policies
- 6.9. API workflows for Code Security issues
  - note: When blockingPoliciesIds is non-empty, the PR was blocked, preventing vulnerable code from merging into the protected branch.
  - note: The severity query parameter is the only server-side filter available on the issue endpoint. Filtering by detection method, resolution status, or assignee requires client-side processing.
  - note: License compliance (License Security) and package operational risk (Operational Risk Security) are not represented as separate keys in issuesTypesBreakdown. To retrieve these issue types, filter client-side by detection_method from the full issue set.
  - note: Application issue summaries return counts only, not individual issue records. To retrieve individual records, list periodic scans for the application's repositories, then use GET /scans/{scanId}/issues.
  - tip: Use the issuesTypesBreakdown and issuesFound fields in the scan list response to identify scans with Critical or High issues before drilling into individual records, thereby reducing API calls.
  - navi…: Generate an API key pair from Settings → Configurations → API Keys in the Cortex Cloud console
- 6.10. Application Security scans management
  - 6.10.1. Manage scans through the tenant (UI)
    - note: While scans provide a comprehensive inventory of all issues detected during a scan, dedicated inventories are also maintained for specific scan types for more granular management. For more information, refer to Code Security scanners.
  - 6.10.2. Branch periodic scans
    - note: The inventory table displays scan issues for visibility only; remediation is not available here. To resolve issues, navigate to the dedicated issue type inventory, where you can manage and remediate them.
  - 6.10.3. Pull Request scans
    - note: The inventory table displays scan issues for visibility only; remediation is not available here. To resolve issues, navigate to the dedicated issue type inventory, where you can manage and remediate them.
  - 6.10.4. CI scans
    - note: The inventory table displays scan issues for visibility only; remediation is not available in scan management. To resolve issues, navigate to the dedicated issue type inventory, where you can manage and remediate them.
  - 6.10.5. Scan health and status reference
    - note: Periodic scans do not have a scan status. Periodic scans produce issues and findings but do not evaluate blocking policies. The scan health status is the only health indicator for periodic scans.
  - 6.10.6. Manage repository scan configurations
  - 6.10.7. Monitor data source instances health
  - 6.10.8. Manage scans through public APIs
- 6.11. Application Security CLI
- 6.12. IDE
  - note: Not all remediation options are available for all findings or all type of scan category.
  - 6.12.1. System requirements
  - 6.12.2. Visual Studio (VS) Code and VS Code compatible IDEs
    - prer…: Before you begin (These prerequisites apply to both VS Code and VS Code compatibles):
      Permissions: CLI Read only permissions. Refer to Cortex CLI for more information about permissionsCortex CLI
      Environment setup
      macOS and Windows: Install Python 3.9.x to 3.12.x
      Install Node.js version 22 and above for SCA scans (such as vulnerabilities…
    - prer…: You must insert your API key and API ID values into the Settings before providing the tenant URL.
    - note: Enforcement rules and CA certificates are not applicable to the open-source project.
    - imp…: When generating an API key, ensure you select the Standard security level. IDE and CLI scans will fail if the security level of the API key is set to Advanced.
    - tip: You can access Extensions using the keyboard shortcuts Ctrl+Shift+X (Windows) or Cmd+Shift+X (macOS).
    - navi…:
      - Settings → Configurations → API Keys (under Integration) → click Copy API URL
      - Install through VS Code IDE Access the Activity bar → Extensions → Cortex Cloud → Install
      - Access the Activity bar → Extensions → Cortex Cloud → Install
    - 6.12.2.1. How to use the Cortex Cloud extension in VS Code
      - note: Not all remediation options are available for all issues.
      - note: The suppression is scoped to the file.
  - 6.12.3. JetBrains
    - prer…: Permissions: CLI Read only permissions. Refer to Cortex CLI for more information about permissionsCortex CLI
      Environment setup
      macOS and Windows: Install Python 3.9.x to 3.12.x
      Install Node.js version 22 and above for SCA scans (such as vulnerabilities scans)
      Environment setup
      macOS and Windows: Install Python 3.9.x to 3.12.x
      Install Node.js…
    - prer…: You must insert your API key and API ID values into the Settings before providing the tenant URL.
    - note: The Cortex AppSec code security plugin supports all JetBrains products.
    - imp…: When generating an API key, ensure you select the Standard security level. IDE and CLI scans will fail if the security level of the API key is set to Advanced.
    - navi…:
      - Settings → Plugins → select the Marketplace tab → search for Prisma Cloud → Install → OK
      - Settings → Tools → Cortex Cloud
    - 6.12.3.1. How to use the JetBrains Cortex Cloud extension
      - note: After selecting Fix Available, the number of issues displayed in the issue categories (such as IaC) reflect the number of fixable issues for that type.
      - note: The corresponding file simultaneously opens in the Code editor, highlighting the issue within its exact code context. See below for more information.
      - note: Not all types of remediation are available for all issue categories. For example, fixes are not available for License issues.
      - note: Secrets and Licenses category issues are typically mitigated by following the guidance in the Documentation.
- 6.13. Developer Suppressions
  - note: The check IDs and rule names are placeholders for illustration purposes and do not correspond to actual checks.

7. API endpoints

8. Terraform workflows

- navi…: To authenticate, you must generate a dedicated API key in the Cortex Cloud console under Settings → Configurations → API Keys
- 8.1. Manage resources
  - note: For a complete list of supported IaC and CI/CD compliance standards, as well as rule mapping logic and available scan types, refer to Compliance for Cortex Cloud Application Security.